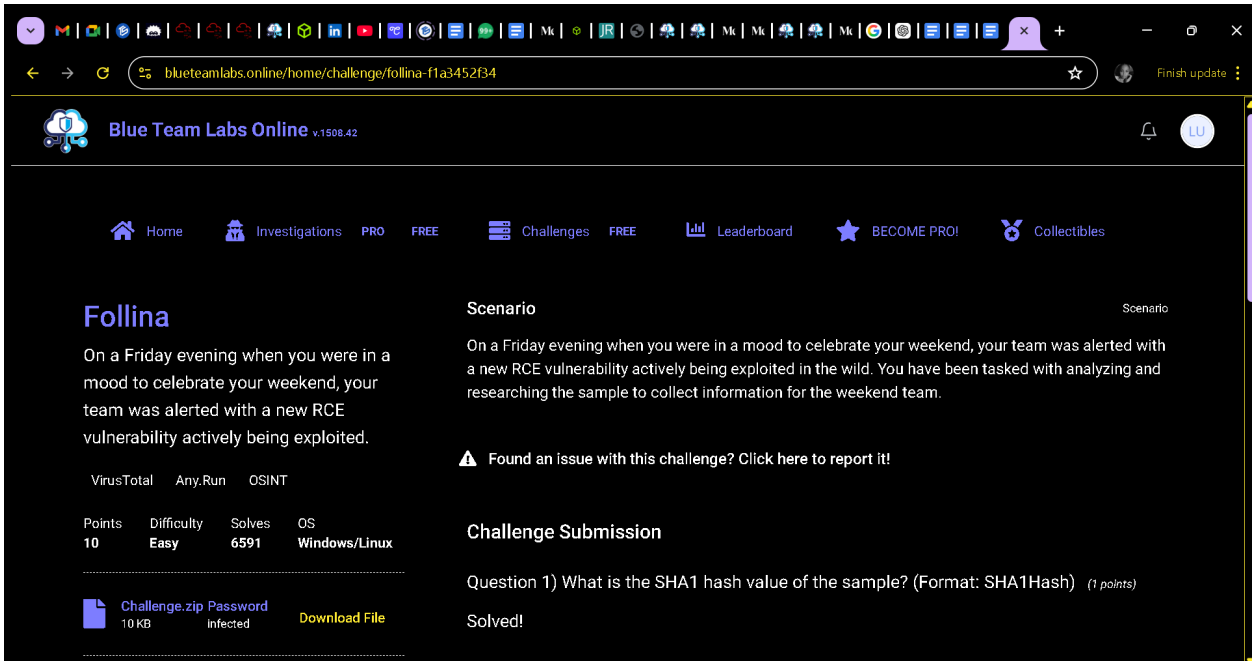
🛡️ Follina Malware Analysis Report



🔴 Attack Summary

This investigation was carried out in a controlled virtual environment after a suspicious document was identified. The file was later confirmed to exploit the **CVE-2022-30190**, which allows remote code execution through Microsoft Word without requiring macros.

🧪 Analysis Environment & Setup

To safely analyze the file, I created a **Windows virtual machine (Windows Dirty)** using VirtualBox.

- The file was downloaded directly inside the VM
- Windows Defender initially blocked the file, so protections were temporarily adjusted to allow extraction

- Immediately after extraction, **network access was disabled** to prevent any outbound communication
- All analysis was performed within the isolated VM

This ensured the host system remained safe throughout the investigation.

📌 Indicators of Compromise (IOCs)

File Indicators

- File name:
- SHA1 hash: 06727ffda60359236a8029e0b3e8a0fd11c23313

Network Indicators

- Malicious URL embedded within the document
- External HTML payload used to trigger the exploit

Process Indicators

- → initial execution
- → spawned via exploit
- Terminated process: *(identified during analysis)*

⚔️ Attack Techniques Identified

The behavior observed aligns with:

- **T1203 – Exploitation for Client Execution**
- **T1059 – Command Execution via MSDT**
- **T1105 – Remote Payload Retrieval**

🚪 Entry Point

The attack begins with the malicious document , which is likely delivered via phishing or as a downloaded attachment.

Once opened, the document silently triggers the vulnerability without requiring macros or user interaction beyond opening the file.

🔍 Investigation Process (What I Actually Did)

1. Extracted the ZIP file using the provided password
2. Identified the sample file ( )
3. Used PowerShell to generate the **SHA1 hash**
4. Uploaded the file to **VirusTotal** for deeper inspection
5. Retrieved:
   - File type
   - Embedded URL
   - Behavioral indicators
6. Avoided executing the file directly to prevent compromise

⛓️ Attack Chain Breakdown

1. **Delivery**
   Malicious Word document is downloaded and opened
2. **Execution**
   Microsoft Word ( ) processes the file
3. **Exploitation**
   Follina vulnerability is triggered via embedded URL
4. **Command Execution**
   is launched and executes attacker-controlled instructions
5. **Payload Retrieval**
   The document connects to a remote server hosting an HTML payload
6. **Defense Evasion**
   A running process is terminated by the malware

🔄 Lateral Movement

No lateral movement was observed.
The attack appears focused on initial compromise and execution.

📤 Data Exfiltration

No direct data exfiltration was identified during this analysis.
However, the external connection indicates potential for further payload delivery.

🧠 Key Findings

- The attack does not rely on macros, making it harder to detect using traditional defenses
- It abuses a legitimate Windows tool ( ) for execution
- The use of an external HTML payload allows attackers to dynamically control the attack

---

🧾 Conclusion

This investigation demonstrates how a seemingly harmless document can be used to exploit a known vulnerability and execute code on a system. By isolating the environment, disabling network access, and leveraging tools like PowerShell and VirusTotal, the malicious behavior was safely analyzed without risking the host machine.